

Pyramid of Pain



Ali

Ali

Digitally signed

by Ali Ali

DN: c=LB,

st=Beirut, l=AA,

o=MISC, ou=ISC,

cn=Ali Ali

Date: 2024.08.28

07:16:20 +03'00'



Pyramid of Pain

Overview

❑ Pyramid of Pain

- The *Pyramid of Pain* is a conceptual model created by David J. Bianco to illustrate the *difficulty an adversary faces when their indicators are detected and denied*
- It is widely used in cybersecurity to *enhance the effectiveness of Cyber Threat Intelligence (CTI), threat hunting, and incident response exercises*

Pyramid of Pain

Overview

- ***The pyramid consists of six levels, each representing different types of indicators:***
 - *Hash Values: Unique identifiers for specific files*
 - *IP Addresses: Addresses used by adversaries*
 - *Domain Names: Domains used for malicious activities*
 - *Network/Host Artifacts: Observable behaviors on networks or hosts*
 - *Tools: Software used by attackers*
 - *Tactics, Techniques, and Procedures (TTPs): Methods and strategies used by adversaries*

- **Hash values** are unique identifiers generated by applying a hash function to a file's content. They are crucial in cybersecurity for identifying and verifying files

1. What is a Hash Value?

- A hash value is a fixed-length string of characters produced by a hash function
- Common hash functions include MD5, SHA-1, and SHA-256. The hash value is unique to the specific content of the file, meaning even a small change in the file will produce a completely different hash value

2. Why are Hash Values Important?

Hash values are used to:

- *Verify File Integrity: Ensure that a file has not been altered*
- *Detect Malicious Files: Identify known malware by comparing hash values against a database of malicious hashes*
- *Track Changes: Monitor files for unauthorized changes*

3. Examples of Hash Values

- *MD5 Hash:*
 - **Original File:** *example.txt* containing "Hello World"
 - **MD5 Hash:** *b10a8db164e0754105b7a99be72e3fe5*
 - *If the file content changes to "Hello World!", the MD5 hash becomes ed076287532e86365e841e92bfc50d8c*

Pyramid of Pain

Hash Values

- *SHA-256 Hash:*
 - **Original File:** *example.txt* containing "Hello World"
 - **SHA-256 Hash:**
a591a6d40bf420404a011733cfb7b190d62c65bf0bcda32b5b9a4e6d3e5b3d1d
 - *Changing the file content to "Hello World!" results in a different SHA-256 hash:*
7f83b1657ff1fc53b92dc18148a1d65dfa135e2b0a1e5c8b6b8a7e6d3e5b3d1d

Pyramid of Pain

Hash Values

4. Real-World Application

- **Malware Detection:** Security tools like antivirus software use hash values to detect known malware. *For example*, if a file's hash matches a hash in the malware database, the file is flagged as malicious
- **File Integrity Verification:** When downloading software, the provider often supplies a hash value. After downloading, you can generate the hash of the downloaded file and compare it to the provided hash to ensure the file has not been tampered with

5. Example Scenario

- Imagine you are a SOC Analyst and you receive a suspicious file. You generate its hash value and compare it against a database of known malicious hashes
- If there is a match, you can quickly identify the file as malicious and take appropriate action



Pyramid of Pain

IP Addresses

- **IP addresses** are unique numerical labels assigned to devices connected to a network, enabling them to communicate over the internet
- In the context of the Pyramid of Pain, IP addresses are used as *indicators of compromise (IOCs)* to identify and track malicious activities

1. Why IP Addresses Matter

IP addresses are crucial in cybersecurity for:

- *Identifying Malicious Sources:* Detecting the origin of attacks
- *Blocking Malicious Traffic:* Preventing communication with known malicious IPs
- *Tracking Adversary Infrastructure:* Understanding the network of an attacker



Ali Ali

2. Examples of IP Addresses in Cybersecurity

- *Identifying Malicious Sources:*
 - *Suppose a security team detects unusual traffic from the IP address 192.168.1.100*
 - *By investigating, they find that this IP is associated with a known botnet*
 - *Blocking this IP can prevent further attacks from this source*
- *Blocking Malicious Traffic:*
 - *An organization might receive phishing emails from the IP address 203.0.113.5*
 - *By adding this IP to their blocklist, they can prevent future phishing attempts from the same source*

Pyramid of Pain

IP Addresses

- *Tracking Adversary Infrastructure:*
 - *During an investigation, a SOC Analyst discovers that multiple attacks are originating from a range of IP addresses within the 198.51.100.0/24 subnet*
 - *This indicates that the adversary is using a specific network segment for their operations*
 - *Blocking this entire subnet can disrupt the attacker's activities*

Pyramid of Pain

IP Addresses

3. Real-World Application

- *Incident Response*: When a breach is detected, responders can quickly identify and block IP addresses associated with the attack, limiting the damage
- *Threat Hunting*: Analysts can proactively search for connections to known malicious IP addresses within their network, identifying potential threats before they cause harm

4. Example Scenario

- Imagine you are a Threat Hunter and you notice repeated login attempts from the IP address **198.51.100.23**
- By cross-referencing this IP with threat intelligence databases, you find it is associated with a known **APT** (Advanced Persistent Threat) group
- You can then take steps to **block this IP and investigate any potential breaches**



Ali Ali

Pyramid of Pain

Domain Name

- **Domain names** are human-readable addresses used to access resources on the internet
- In the context of the Pyramid of Pain, domain names are used by adversaries to host malicious content, command and control (C2) servers, phishing sites, and more
- Detecting and blocking these domains can significantly disrupt an attacker's operations

1. Why Domain Names Matter

Domain names are crucial in cybersecurity for:

- **Identifying Malicious Websites:** Detecting domains used for phishing, malware distribution, or other malicious activities



Ali Ali

Pyramid of Pain

Domain Name

- *Blocking Access: Preventing users from accessing known malicious domains*
- *Tracking Adversary Infrastructure: Understanding the network of domains used by attackers*

2. Examples of Domain Names in Cybersecurity

- *Phishing Sites:*
 - *Example: An attacker might use the domain [login-secure.com](#) to create a fake login page that mimics a legitimate site*
 - *Users who enter their credentials on this page unknowingly give them to the attacker*

Pyramid of Pain

Domain Name

- *Malware Distribution:*
 - *Example: A domain like download-software.net could be used to host and distribute malware*
 - *When users visit this site and download the software, they inadvertently install malicious code on their systems*
- *Command and Control (C2) Servers:*
 - *Example: Attackers might use a domain such as control-server.org to communicate with compromised devices*
 - *This domain acts as a central point for sending commands to and receiving data from infected machines*

Pyramid of Pain

Domain Name

3. Real-World Application

- *Incident Response*: When a malicious domain is detected, responders can block it at the network level to prevent further communication with the attacker's infrastructure
- *Threat Hunting*: Analysts can search for connections to known malicious domains within their network traffic, identifying potential threats before they cause harm

4. Example Scenario

- Imagine you are a SOC Analyst and you notice traffic to the domain *secure-login.com*
- By investigating, you find that this domain is associated with a phishing campaign targeting your organization
- You can then block this domain to prevent users from falling victim to the phishing attack and investigate any potential breaches



Ali Ali

Pyramid of Pain

Network/Host Artifacts

- **Network/Host Artifacts** are observable behaviors or traces left by adversaries on networks or host systems
- These artifacts can include specific patterns, files, registry keys, or other indicators that reveal malicious activity
- In the context of the Pyramid of Pain, detecting and responding to these artifacts can significantly disrupt an attacker's operations

1. Why Network/Host Artifacts Matter

Network/Host artifacts are crucial in cybersecurity for:

- **Identifying Malicious Activities:** Detecting unusual behaviors or traces that indicate a compromise
- **Tracking Attacker Movements:** Understanding how attackers navigate and interact with the network or host



Ali Ali

Pyramid of Pain

Network/Host Artifacts

- *Implementing Countermeasures: Applying specific defenses to mitigate detected threats.*

2. Examples of Network/Host Artifacts

- *Command and Control (C2) Information:*
 - *Example: An attacker might use specific patterns in network traffic to communicate with a C2 server*
 - *For instance, unusual HTTP headers or specific User-Agent strings can indicate C2 communication. Detecting these patterns can help identify and block the C2 server*

Pyramid of Pain

Network/Host Artifacts

■ *Registry Keys:*

- *Example: Malware often creates or modifies registry keys to maintain persistence on a host*
- *For instance, a registry key like `HKCU\Software\Microsoft\Windows\CurrentVersion\Run\malware` might be used to ensure the malware runs on startup. Detecting such keys can help identify and remove the malware*

■ *Files and Directories:*

- *Example: Attackers might drop specific files or create directories on a compromised host*
- *For instance, a file named `backdoor.exe` in the `C:\Windows\System32` directory could indicate a backdoor installed by the attacker. Monitoring for such files can help detect and respond to compromises*



Pyramid of Pain

Network/Host Artifacts

■ *URL Patterns:*

- *Example: Specific URL patterns used by attackers to exfiltrate data or communicate with compromised systems*
- *For instance, URLs like `http://malicious-site.com/data?file=confidential.txt` can indicate data exfiltration attempts. Detecting these patterns can help prevent data breaches*



3. Real-World Application

- *Incident Response*: When a breach is detected, responders can look for network/host artifacts to understand the scope of the attack and take appropriate actions to contain and remediate it
- *Threat Hunting*: Analysts can proactively search for known artifacts within their network or host systems to identify potential threats before they cause harm

4. Example Scenario

- *Imagine you are an Incident Responder and you detect unusual network traffic with specific HTTP headers that match known C2 patterns*
- *By investigating further, you find that the traffic is coming from a compromised host*
- *You then check the host and discover a suspicious registry key and a file named **backdoor.exe**. By removing these artifacts and blocking the C2 server, you can effectively disrupt the attacker's operations and secure your network*

Pyramid of Pain

Tools

- **Tools** in the context of the Pyramid of Pain refer to software and utilities used by attackers to carry out their malicious activities
- These tools can range from simple scripts to sophisticated programs designed to exploit vulnerabilities, maintain persistence, or exfiltrate data

1. Why Tools Matter

Tools are crucial in cybersecurity for:

- **Understanding Attacker Capabilities:** Identifying the tools used by attackers helps in understanding their capabilities and methods
- **Detecting Malicious Activities:** Recognizing specific tools can help in detecting and mitigating attacks



Pyramid of Pain

Tools

- *Implementing Countermeasures: Knowing the tools allows defenders to develop specific countermeasures to disrupt the attacker's operations*

2. Examples of Tools Used by Attackers

- *Malware Creation Tools:*
 - *Example: **Metasploit** is a widely used penetration testing framework that can be used to create and execute exploits*
 - *While it is a legitimate tool for security professionals, attackers can use it to develop and deploy malware*

Pyramid of Pain

Tools

■ *Backdoors:*

- *Example: **Cobalt Strike** is a tool used for post-exploitation, providing attackers with a backdoor to maintain access to compromised systems*
- *It allows attackers to execute commands, upload/download files, and pivot to other systems within the network*

■ *Password Crackers:*

- *Example: **John the Ripper** is a popular password cracking tool that can be used to break weak passwords*
- *Attackers use it to gain unauthorized access to systems by cracking password hashes*

Pyramid of Pain

Tools

■ *Phishing Kits:*

- *Example: **Evilginx** is a tool used to create phishing sites that can bypass two-factor authentication (2FA)*
- *It acts as a man-in-the-middle proxy, capturing credentials and session cookies from victims*

■ *Network Scanners:*

- *Example: **Nmap** is a network scanning tool used to discover hosts and services on a network*
- *Attackers use it to map out the network and identify potential targets and vulnerabilities*

3. Real-World Application

- *Incident Response*: When a breach is detected, responders can look for specific tools used by the attacker to understand the scope of the attack and take appropriate actions to contain and remediate it
- *Threat Hunting*: Analysts can proactively search for known tools within their network or host systems to identify potential threats before they cause harm

4. *Example Scenario*

- *Imagine you are a Threat Hunter and you detect the presence of Cobalt Strike on a compromised host*
- *By investigating further, you find that the attacker has used this tool to establish a backdoor and maintain persistence*
- *You can then take steps to remove the backdoor, block the attacker's access, and investigate any potential breaches*

Pyramid of Pain

TTP

- **Tactics, Techniques, and Procedures (TTPs)** represent the methods and strategies used by adversaries to achieve their objectives
- In the context of the Pyramid of Pain, TTPs are at the top of the pyramid, indicating that detecting and disrupting them can significantly hinder an attacker's operations

1. Why TTPs Matter

TTPs are crucial in cybersecurity for:

- **Understanding Adversary Behavior:** Identifying the methods and strategies used by attackers helps in predicting and mitigating future attacks
- **Developing Defensive Strategies:** Knowing the TTPs allows defenders to create specific countermeasures to disrupt the attacker's operations



Ali Ali

Pyramid of Pain

TTP

- *Enhancing Threat Intelligence*: Sharing information about TTPs improves the overall security posture by enabling organizations to learn from each other's experiences

2. Examples of Tactics, Techniques, and Procedures

- *Tactics*:

- *Example: Initial Access* - Attackers use various methods to gain initial access to a target network. This can include phishing, exploiting vulnerabilities, or using stolen credentials

- *Techniques*:

- *Example: Phishing* - A technique used to trick individuals into providing sensitive information or installing malware. Attackers might send emails that appear to be from legitimate sources, containing malicious links or attachments



Pyramid of Pain

TTP

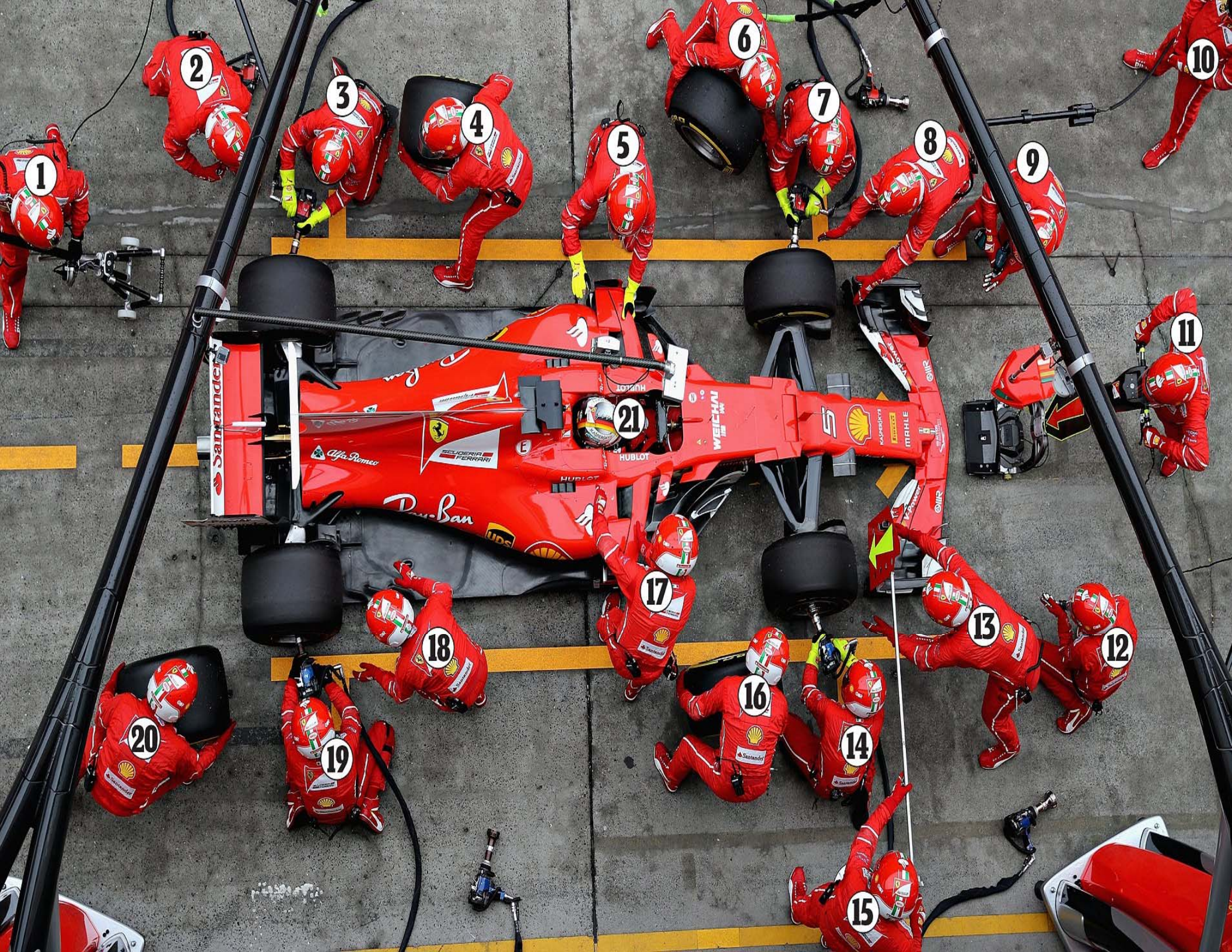
- *Procedures:*
 - **Example: Credential Dumping** - A procedure where attackers extract credentials from a compromised system. Tools like **Mimikatz** can be used to dump passwords from memory, allowing attackers to move laterally within the network

3. Real-World Application

- **Incident Response:** When a breach is detected, responders can analyze the TTPs used by the attacker to understand the scope of the attack and take appropriate actions to contain and remediate it
- **Threat Hunting:** Analysts can proactively search for known TTPs within their network or host systems to identify potential threats before they cause harm

4. Example Scenario

- *Imagine you are a SOC Analyst and you detect a phishing email that successfully tricked an employee into providing their credentials*
- *By analyzing the TTPs, you find that the attacker used the credentials to gain initial access and then used **Mimikatz** to dump additional credentials*
- *You can then take steps to remove the attacker's access, reset compromised passwords, and implement additional security measures to prevent similar attacks in the future*



Questions

THANK YOU!



Ali Ali

Ali Ali